DICHIARAZIONE DI CONFORMITÀ TECNICA

Archibald PWA — Misure di Sicurezza e Protezione dei Dati

Documento: Dichiarazione di Conformità Tecnica n. 2026-001
Data di emissione: 5 aprile 2026
Emessa da: Formicola Francesco — Sviluppatore e Responsabile del Trattamento
Destinatario: Komet Italia S.r.l. — Titolare del Trattamento
Software oggetto: Archibald PWA (Progressive Web Application per la gestione degli ordini e dei clienti della rete vendita Komet)
Infrastruttura: VPS Hetzner CPX32, formicanera.com, 4 vCPU / 8 GB RAM, 160 GB SSD, Regione EU (Falkenstein, Germania)

Art. 1 — Oggetto e Finalità

Il sottoscritto Formicola Francesco, in qualità di Responsabile del Trattamento ai sensi dell'art. 28 del Regolamento (UE) 2016/679 (GDPR), dichiara che il sistema software Archibald PWA, da lui sviluppato e mantenuto per conto di Komet Italia S.r.l. (Titolare del Trattamento), è stato aggiornato per conformarsi ai requisiti di sicurezza applicabili ai trattamenti di dati personali dei clienti e degli agenti della rete vendita Komet.

Il presente documento certifica le misure tecniche e organizzative implementate ai sensi:

- Art. 32 GDPR — Sicurezza del trattamento
- Direttiva NIS 2 (UE 2022/2555), recepita con D.Lgs. 138/2024 — Misure di sicurezza per fornitori ICT nella supply chain
- Art. 5(1)(e) GDPR — Limitazione della conservazione dei dati
- Art. 17 GDPR — Diritto alla cancellazione
- Art. 20 GDPR — Diritto alla portabilità dei dati

Art. 2 — Misure di Sicurezza Tecniche Implementate

2.1 — Autenticazione e Gestione delle Sessioni

a) Autenticazione JWT con revoca attiva via Redis

Il sistema implementa token di accesso JWT (JSON Web Token) con i seguenti meccanismi di sicurezza:

- Ogni token contiene un identificatore univoco (`jti` , UUID v4) generato crittograficamente.
- Al logout, il `jti` del token viene inserito in una lista di revoca persistita in Redis con TTL dinamico calcolato dalla scadenza del token.
- Il middleware di autenticazione verifica la revoca del token a ogni richiesta prima di accettarlo.
- Redis è protetto da password generata crittograficamente (`--requirepass`).

Risultato: Impossibile riutilizzare un token dopo il logout, anche se non scaduto. I token rubati cessano di essere validi nel momento in cui l'utente effettua il logout.

b) Multi-Factor Authentication (MFA) TOTP

Il sistema supporta l'autenticazione a due fattori tramite TOTP (Time-based One-Time Password, RFC 6238):

- Il segreto TOTP è cifrato con AES-256-GCM con IV casuale prima della persistenza nel database; non è mai accessibile in chiaro né alle applicazioni né al personale tecnico.
- Il processo di setup restituisce esclusivamente l'URI TOTP per la scansione del QR code; il segreto raw non transita mai nelle risposte HTTP.
- Sono forniti 8 codici di recupero monouso, hashati con bcrypt, per il caso di perdita del dispositivo.
- L'MFA è disponibile per tutti i ruoli tramite configurazione volontaria dal profilo utente. Non è imposta automaticamente dal sistema; l'attivazione è a discrezione dell'amministratore e dell'utente.
- L'endpoint di configurazione MFA è protetto da rate limiting (max 5 tentativi per 15 minuti per IP).

c) Rate Limiting su tutti gli endpoint sensibili

Endpoint	Finestra	Limite	Risposta al superamento
POST /api/auth/login	15 minuti	5 tentativi	HTTP 429 + audit log
POST /api/auth/refresh	60 minuti	20 richieste	HTTP 429
POST /api/auth/mfa-verify	15 minuti	10 tentativi	HTTP 429
POST /api/auth/mfa-setup	15 minuti	5 richieste	HTTP 429
POST /api/auth/mfa-confirm	15 minuti	5 richieste	HTTP 429

Ogni superamento di soglia per il login è registrato nel log di audit.

2.2 — Crittografia e Protezione delle Credenziali

a) Password degli agenti ERP

Le credenziali di accesso all'ERP Archibald (username e password) degli agenti sono cifrate con AES-256-GCM con IV casuale generato per ogni cifratura e autentication tag per rilevazione di manomissioni. Il materiale crittografico (IV, auth tag, ciphertext) è separato dalla chiave, mai serializzato insieme. La chiave di cifratura è derivata da una secret key d'ambiente (`ENCRYPTION_KEY`) non presente nel codice sorgente né nel repository.

b) Trasmissione

Tutte le comunicazioni tra il client (PWA) e il server avvengono esclusivamente via HTTPS con TLS 1.2+, gestito da Nginx con certificato Let's Encrypt rinnovato automaticamente.

2.3 — Log di Audit Immutabile

Il sistema mantiene un log di audit persistente e immutabile nella tabella `system.audit_log` del database PostgreSQL:

Struttura: ogni record include `occurred_at` , `actor_id` , `actor_role` , `action` , `target_type` , `target_id` , `ip_address` , `user_agent` , `metadata JSONB` .

Immutabilità garantita a livello database: il comando SQL `REVOKE UPDATE, DELETE ON system.audit_log FROM archibald` impedisce all'utente applicativo di modificare o cancellare qualsiasi record. La rimozione di record richiede accesso diretto del superuser al database, con credenziali separate non utilizzate dall'applicazione.

Eventi tracciati:

- Tutti i login (riusciti e falliti), logout, refresh di token
- Creazione, modifica, cancellazione ordini (singoli e in batch)
- Creazione e modifica clienti
- Cancellazione GDPR (erase) dei dati personali — con timestamp e operatore
- Export GDPR dei dati personali — con timestamp e operatore
- Modifiche alla whitelist di prodotti autorizzati
- Alert di sicurezza (circuit breaker, rate limit, errori di autenticazione ripetuti)
- Operazioni di gestione utenti (assegnazione ruoli, moduli, MFA)

2.4 — Controllo degli Accessi (RBAC)

a) Quattro livelli di ruolo

Ruolo	Descrizione	MFA obbligatoria
`admin`	Accesso completo incluso pannello di amministrazione, audit log, gestione utenti	Facoltativa
`ufficio`	Accesso operativo avanzato (fatture, DDT, storico completo)	Facoltativa
`agent`	Accesso standard agente (clienti propri, ordini propri, prodotti)	Facoltativa
`concessionario`	Accesso concessionario (storico Fresis, ordini Fresis)	Facoltativa

b) Moduli per-utente

Ogni utente dispone di un array di moduli abilitati (`modules JSONB`) che limitano l'accesso alle funzionalità specifiche (es. accesso al magazzino, alla sezione Arca, all'export FT). L'assegnazione dei moduli è gestita esclusivamente dall'amministratore.

c) Guard di protezione dell'amministratore

Un amministratore non può modificare il proprio ruolo tramite l'applicazione (protezione contro auto-blocco accidentale). La modifica dei propri moduli rimane consentita.

2.5 — Intestazione di Sicurezza HTTP

Content Security Policy (CSP):

```
default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline';
img-src 'self' data:; connect-src 'self' wss:; font-src 'self';
object-src 'none'; frame-src 'none'
```

CORS: le richieste cross-origin sono accettate esclusivamente dalle origini configurate nell'ambiente di produzione (`https://formicanera.com`). Richieste da origini non autorizzate sono rifiutate a livello di middleware.

Ulteriori header Helmet: `X-Frame-Options: DENY` , `X-Content-Type-Options: nosniff` , `Strict-Transport-Security` , `X-XSS-Protection` .

2.6 — Audit di Sicurezza Automatico nel CI/CD

La pipeline di integrazione continua (GitHub Actions) esegue `npm audit --audit-level=critical` su ogni push. Vulnerabilità critiche bloccano il build e il deploy automatico. Ciò garantisce che il software non venga distribuito in produzione con vulnerabilità note di livello critico nelle dipendenze.

Art. 3 — Misure relative ai Diritti degli Interessati (GDPR)

3.1 — Diritto alla Cancellazione (Art. 17 GDPR)

L'endpoint `POST /api/admin/customers/:id/gdpr-erase` consente all'amministratore di eseguire la cancellazione ("anonimizzazione") dei dati personali di un cliente su richiesta dell'interessato.

Campi anonimizzati in `agents.customers`: name, street, city, postal_code, email, phone, mobile, pec, sdi, fiscal_code.

Campi anonimizzati in `shared.sub_clients` (clienti Fresis collegati): ragione_sociale, pers_da_contattare, email, email_amministraz, telefono, telefono2, telefono3, cod_fiscale, partita_iva.

Meccanismo: i campi sono sostituiti con un marker `[GDPR_ERASED_<timestamp ISO>]` tracciabile. I dati strutturali (ordini, storico) sono conservati per obblighi contabili e fiscali, ma privi di riferimenti identificativi.

Guardia: l'operazione è bloccata se il cliente ha ordini in stato attivo (non consegnati/fatturati/pagati).

Audit: ogni erase è registrato in `system.audit_log` con action `gdpr.erase`, actor_id dell'amministratore, e customer_profile_id del cliente.

3.2 — Diritto alla Portabilità (Art. 20 GDPR)

L'endpoint `GET /api/admin/customers/:id/export` produce un archivio JSON strutturato contenente tutti i dati del cliente presenti nel sistema: anagrafica, ordini, articoli ordinati, sotto-clienti collegati.

Il file è restituito con header `Content-Disposition: attachment` per il download diretto. Ogni export è registrato in audit log con action `gdpr.export`.

3.3 — Retention Policy Automatica

Il sistema implementa un controllo settimanale (ogni domenica, UTC) per l'identificazione di clienti con assenza di attività superiore a 24 mesi. Quando rilevati, il sistema invia una notifica di avviso all'agente responsabile tramite il sistema interno di notifiche.

Questo flusso supporta la politica di conservazione dei dati personali prevista dall'art. 5(1)(e) GDPR (principio di limitazione della conservazione), senza procedere ad alcuna cancellazione automatica (che rimane sempre un atto umano deliberato).

La data dell'ultima attività (`last_activity_at`) è aggiornata automaticamente a ogni creazione di ordine per il cliente.

Art. 4 — Backup e Continuità Operativa

Frequenza: backup notturno automatico (ore 02:00 CET via cron sul VPS).

Processo: `pg_dump` → compressione gzip → upload su Hetzner Object Storage (regione `fsn1`, Frankfurt, Germania, all'interno dell'UE).

Rotazione: i backup più vecchi di 30 giorni sono eliminati automaticamente.

Verifica: ogni esecuzione di backup è verificabile nei log del container dedicato.

RTO/RPO: in caso di failure del VPS, il ripristino del database è eseguibile dall'ultimo backup disponibile (max 24 ore di perdita dati). Per il codice sorgente, il repository GitHub è la fonte autoritativa e permette il rideploy in ambiente fresh in 30-60 minuti.

Art. 5 — Gestione degli Incidenti

Una procedura formale di risposta agli incidenti è documentata in `docs/compliance/incident-response-procedure.md`. La procedura definisce:

- Classificazione degli incidenti in P1/P2/P3 con relative finestre di risposta
- Notifica obbligatoria al Titolare del Trattamento entro 24 ore da un incidente P1 (data breach)
- Obbligo di notifica al Garante per la Privacy entro 72 ore (a cura del Titolare, art. 33 GDPR)
- Processo di documentazione e post-mortem

Il sistema genera alert di sicurezza automatici (registrati in audit log con action `security.alert`) per i seguenti eventi: login falliti ripetuti, attivazione del circuit breaker, rate limit superato, errori di sistema ad alto tasso.

Art. 6 — Sub-Processor

I fornitori terzi che trattano dati personali per conto del sistema Archibald sono documentati in `docs/compliance/sub-processors.md`. Al momento dell'emissione del presente documento:

Fornitore	Ruolo	Dati trattati	Sede	Garanzie
Hetzner Online GmbH	Hosting VPS + Object Storage	Tutti i dati del sistema	Germania (UE)	Contratto DPA firmato, certificazioni ISO 27001
FedEx International	Tracking spedizioni	Numero di tracciatura ordini	USA	Standard Contractual Clauses (SCC)

Nessun servizio di email esterno è utilizzato per le notifiche di sicurezza (gestite tramite audit log interno e link mailto).

Art. 7 — Dichiarazione Finale

Il sottoscritto dichiara sotto la propria responsabilità che le misure tecniche e organizzative descritte nel presente documento sono state effettivamente implementate nel codice sorgente del sistema Archibald PWA e sono operative in produzione dal 5 aprile 2026.

Le misure implementate sono proporzionate alla natura, all'ambito, al contesto e alle finalità del trattamento, nonché ai rischi per i diritti e le libertà delle persone fisiche, come richiesto dall'art. 32(1) GDPR.

Luogo e Data: _____, 5 aprile 2026

Firma del Responsabile del Trattamento:

Formicola Francesco
Sviluppatore Software Indipendente

Responsabile del Trattamento per conto di Komet Italia S.r.l.
P.IVA: [DA INSERIRE DOPO APERTURA]

Documento generato il 2026-04-05. Versione 1.0.
Hash commit di riferimento: `fd9f3421` *(branch master, merge PR #13 feat/compliance-nis2-gdpr)*
Conservare copia firmata assieme al Data Processing Agreement (DPA-art28-gdpr.md).